Résumé d'examen – Cryptographie et Sécurité Informatique

Oct 1, 2026 · @Firas

1. Concepts de base

À retenir : une **attaque** = une **menace** qui **exploite** une **vulnérabilité** d'un **actif** ; le **risque** est la probabilité que cela arrive et cause un dommage.

Terme	Définition (cours)	Exemple
Actif (asset)	Tout ce qui a une valeur pour l'entreprise : personnes, matériels, logiciels, services/protocoles, infrastructures	Serveur, base clients
Vulnérabilité (faille)	Une faiblesse au niveau d'un actif ; étudiée par un pentest	Pas de mot de passe, mot de passe faible, antivirus absent ou sans MAJ
Incident	Un dysfonctionnement signalé par un utilisateur	Poste qui plante
Menace	Cause potentielle d'un incident : tout ce qui pourrait exploiter une vulnérabilité	Virus face à un PC sans antivirus
Risque	Probabilité qu'une menace se transforme en événement réel entraînant un dommage	
Attaque	Acte intentionnel et malveillant : réalisation de la menace, nécessite l'exploitation d'une vulnérabilité	Ransomware
Contre-mesure	Technologie, dispositif ou procédure pour contrer un incident/une attaque. **Préventive** ou **corrective**	Pare-feu (prév.), sauvegarde/restauration (corr.)

Système d'information (SI) : ensemble des données et des ressources matérielles et logicielles permettant de les stocker ou de les faire circuler (acquérir, stocker, transformer, diffuser, exploiter les informations). Sécuriser l'information ⇒ sécuriser le système informatique.

Sécurité informatique : ensemble des moyens mis en œuvre pour réduire la vulnérabilité d'un système contre les menaces **accidentelles ou intentionnelles**.

Démarche pour sécuriser un SI (6 étapes, dans l'ordre)

1. **Analyse de la situation** : identifier le contexte et le périmètre de sécurité (« on ne sécurise pas de la même manière une maison, une banque ou une gare »).
2. **Analyse des risques** : diminuer le risque global.
   a. Inventaire des éléments à protéger
   b. Inventaire des menaces possibles
   c. Estimation de la probabilité de chaque menace
   d. Estimation du coût de chaque incident
3. **Politique de sécurité** : élaborée **après** l'analyse des risques et **avant** les mesures ; décrit comment le risque sera diminué (audit, tests d'intrusion, détection, réaction, restauration + sensibilisation des utilisateurs).
4. **Mesures de sécurité** : techniques (firewall, antivirus…) et organisationnelles (procédure de secours, nomination d'un responsable sécurité…).
5. **Implémentation** : installation des mesures.
6. **Validation** : vérifier la protection obtenue (audits, scans de vulnérabilité, tests d'intrusion).

Matrice fréquence × coût (traitement du risque)

	Coût élevé	Coût faible
Incident fréquent	Mettre en place des mécanismes, recruter, former	Assurer la disponibilité (serveurs miroirs…)
Incident rare	S'assurer (assurance)	Accepter

Le risque « zéro » n'existe pas : on définit le **risque résiduel** acceptable. Les principaux risques restent banals : câble déchiré, panne de courant, crash disque, mauvais profil utilisateur.

2. Hackers, phases du piratage et besoins de sécurité (DICP)

Classes de hackers

Type	Caractéristique clé
White Hat	Hacker éthique, aide les entreprises à trouver leurs failles (tests d'intrusion). Slogan : « apprendre l'attaque pour mieux se défendre »
Black Hat (cracker)	Illégal, appât du gain : vol de données, virus, intrusions ; parfois lié au crime organisé
Grey Hat	Mélange : s'introduit sans autorisation mais pour exposer une faille dans l'intérêt des clients
Hacktiviste	Vise un changement social, une cause politique ou religieuse ; attaque plutôt des entreprises
Script-kiddie	Utilise des outils écrits par d'autres, peu compétent, mais peut faire autant de dégâts

Hacking = exploiter les vulnérabilités pour accéder à des ressources non autorisées.
Ethical hacking = utiliser les mêmes outils pour identifier les faiblesses.

Motivations : gain financier (revente de données, cartes bancaires), utilisation des ressources, chantage, perturbation, espionnage. Statistiques du cours : 27 % des menaces viennent de l'intérieur, 26 % raison politique, 26 % concurrents, 24 % cyberguerre, 20 % utilisateurs mécontents, 11 % motifs inconnus.

Impacts sur la vie privée : divulgation d'informations, cyberharcèlement, usurpation d'identité, perte définitive de données (rançongiciel), impacts financiers. Exemple : hôpital de Villefranche-sur-Saône, ransomware RYUK, février 2021.

Les 5 phases du piratage (cycle)

1. **Reconnaissance** : collecter de l'information sur la cible. *Passive* = sans interagir avec la cible ; *active* = interaction directe.
2. **Scanning (analyse)** : explorer le réseau avec des scanners de ports et de vulnérabilités (noms de machines, IP, comptes).
3. **Gaining access (exploitation)** : l'attaque réussit, le pirate utilise les failles pour entrer (LAN, accès local, Internet, hors ligne).
4. **Maintaining access** : installer un accès persistant pour revenir plus tard.

5. **Clearing tracks** : effacer les traces (journaux, alertes IDS) pour éviter détection et poursuites.

Besoins de sécurité

Besoin	Définition
Disponibilité	Le bien est accessible au moment voulu par les personnes autorisées
Intégrité	Les données n'ont pas été modifiées entre création et transfert
Confidentialité	Seules les personnes autorisées ont accès aux ressources
Preuve	Retrouver les circonstances d'évolution du bien : traçabilité, authentification, imputabilité
Non-répudiation	Une transaction ne peut pas être niée
Authentification	Seules les personnes autorisées (identité vérifiée) accèdent aux ressources

Exemple d'évaluation DICP — site vitrine statique : Disponibilité très forte, Intégrité très forte (un concurrent ne doit pas modifier le contenu), Confidentialité faible (infos publiques), Preuve faible (aucune interaction).

Mécanismes typiques : D → sauvegardes, redondance, anti-DDoS ; I → hachage, signature ; C → chiffrement, contrôle d'accès ; P → journaux, signature, certificats.

3. Les méthodes d'attaques (chapitre 2)

Quatre familles : **malwares**, **attaques par messagerie**, **attaques réseau**, **attaques web**. Pour chaque attaque, sachez donner définition + exemple + protection.

3.1 Malwares

Malware	Ce qu'il faut savoir	Exemples	Protection
Virus	A **besoin d'un hôte** (exécutable, document, macro, secteur de démarrage) ; se copie dans d'autres fichiers ; état actif ou passif	ILOVEYOU, CryptoLocker, Jigsaw, Freak	Antivirus, ne pas ouvrir les PJ exécutables/macros, OS à jour
Ver (worm)	**Pas besoin d'hôte**, se propage seul via le réseau. 2 types : exploite une faille technique / exploite la crédulité humaine	Ver Skype/MSN, Stuxnet (centrifugeuses iraniennes, via USB), Netsky (Outlook)	Pare-feu, antivirus, mises à jour, sauvegardes
Cheval de Troie (trojan)	Se présente comme un programme utile ; peut contenir tout autre malware. Vecteurs : logiciels piratés/P2P, pages web, PJ, clé USB	Sunburst/SolarWinds (18 000 clients, déc. 2020)	Antivirus, nettoyage régulier. Symptômes : souris anormale, programmes qui s'ouvrent seuls, plantages
Porte dérobée (backdoor)	Accès distant caché, laisse un port ouvert pour une intrusion future	Toyota GSPIMS (2022)	Antivirus + pare-feu, MAJ, logiciels officiels

Malware	Ce qu'il faut savoir	Exemples	Protection
Keylogger	Enregistre les frappes clavier (mots de passe, cartes)	Olympic Vision (2016), étudiant britannique (2015)	Antivirus, Spybot, **clavier virtuel**, mots de passe changés
Ransomware	Chiffre les données et exige une rançon	VMware ESXi (fév. 2023), RYUK	Pare-feu, antivirus, MAJ, pas de clé USB inconnue

Réagir à un ransomware actif : Isoler → Enquêter (souche, décrypteur ?) → Récupérer (sauvegarde ; payer déconseillé) → Renforcer (leçons apprises) → Évaluer.

3.2 Attaques par messagerie

- **Phishing (hameçonnage)** : message frauduleux semblant venir d'une source fiable pour voler des données ou installer un malware ; joue sur la peur, l'urgence, la curiosité, la cupidité. Trois types : *traditionnel* (impersonnel, massif, urgent, hyperlien), *spear phishing* (ciblé, personnalisé, groupe restreint), *avec trojan downloaders*. Effets : usurpation d'identité, fraude, vol de données. Protection : ne pas cliquer, se méfier des pop-ups, filtrage d'URL.
- **Spam (pourriel)** : communication non sollicitée ; formes : escroquerie, publicitaire. Protection : ne pas divulguer son adresse, adresse secondaire, ne pas ouvrir/répondre.
- **Hoax (canular)** : incite à retransmettre le message ; encombre le réseau, fait perdre du temps, peut pousser à des manipulations dangereuses. Protection : hoaxbuster.com, hoaxkiller.fr, méfiance envers « ce n'est pas une blague ».

3.3 Attaques réseau

Attaque	Principe	Protection
DoS	Rendre un service indisponible depuis **une seule** connexion, par saturation ou par exploitation de vulnérabilités	Scanner ses ports, fermer les inutiles (firewall), IDS (Prelude, OSSIM)

Attaque	Principe	Protection
DDoS	**Plusieurs** sources ; attaque par réflexion ; **SYN flooding** : envoi massif de SYN sans finir la poignée de main TCP (SYN / SYN-ACK / ACK) → connexions semi-ouvertes saturent le serveur	Idem DoS
Sniffing (reniflage)	Capturer les paquets ; facile sur un **hub** (trame envoyée à tous). Filtre port 25 = mails, 80/8080 = web, 21 = FTP	**Switch** plutôt que hub, Snort/Sniffdet, HTTPS, éviter réseaux publics
Spoofing	Usurpation : mail (PHPMailer → contré par **SPF**), **ARP** (fausse réponse ARP associant l'IP à la MAC de l'attaquant → arpwatch, NIDS), **IP** (masquer la source, ou abuser d'une relation de confiance → anti-spoofing du firewall, IPsec)	voir colonne Principe
Scanning	Balayer les ports avec un scanner ; déduit ports ouverts, OS, applications	Scanner soi-même, firewall, IDS
Man in the Middle	S'interposer entre A et B : M substitue sa clé publique KM à KB ; A chiffre avec KM, M déchiffre, lit/modifie, rechiffre avec KB	HTTPS, vérifier le hotspot, VPN, **SAS**

MITM wifi public : l'attaquant crée un faux hotspot, les clients s'y connectent, lui se connecte au vrai réseau.

SAS (Short Authenticated Strings, WhatsApp) : A reçoit KB ; B calcule h = H(KB) et l'envoie par un canal sûr ; A calcule h′ = H(KB reçue) ; si h = h′, la clé est bien celle de B.

3.4 Attaques web

- **Injection SQL** : injecter une portion de requête non prévue faute de contrôle des paramètres. Exemple : `SELECT * FROM users WHERE utilisateur='$login' AND motdepasse='$password'` avec login `' OR 1=1 --` → condition toujours vraie, connexion sans mot de passe ; `admin' --` → connexion en admin. Variantes graves : `'; DROP TABLE users;`, `xp_cmdshell 'net stop firewall'`, `shutdown with nowait`. Protection : requêtes préparées, validation/échappement des entrées.

- **XSS (Cross-Site Scripting)** : injection de script côté client pour voler cookies/jetons de session. *Réfléchie (temporaire)* : le script est dans la requête/URL et renvoyé dans la page. *Stockée* : enregistré en base (ex. commentaire `<script>alert(document.cookie)</script>`) et exécuté à chaque affichage. Protection : **encoder** les entrées/sorties (`<` → `<`), **filtrer** (`<script>`, `onClick`…).
- **CSRF** : faire exécuter à un utilisateur **authentifié** une action involontaire. 3 conditions : action pertinente, session gérée par cookies, aucun paramètre imprévisible. Protection : **jetons CSRF** aléatoires et uniques par requête, attribut **SameSite** sur les cookies.
- **Manipulation d'URL** : modifier les paramètres d'URL pour accéder à des pages non prévues.

4. Cryptographie : définitions et cryptographie classique (chapitre 3)

Vocabulaire

- **Stéganographie** (écriture couverte) : l'information est **cachée** dans une autre (ex. message tatoué sur le crâne d'un esclave). **Cryptographie** : l'information est **rendue incompréhensible**.
- Protagonistes : **Alice** et **Bob** communiquent, **Mallory** est l'attaquant.
- Message clair M, clé, **chiffrement** C = E_ke(M), **déchiffrement** M = D_kd(C), donc D(E(M)) = M.
- **Cryptographie** = science du chiffrement ; **cryptanalyse** = étude des messages chiffrés pour en découvrir le secret ; **cryptologie** = les deux.
- Deux familles classiques : **substitution** (les éléments sont remplacés) et **transposition** (l'ordre des éléments change).

Substitution 1 : chiffre de César

Décalage de l'alphabet de k positions (César utilisait k = 3).

$$C = (M + k) \bmod 26 \qquad M = (C - k) \bmod 26$$

Exemple (k = 3) : CRYPTOGRAPHIE → **FUBSWRJUDSKLH**.

Faiblesses : seulement **26 clés** → force brute en quelques minutes ; et **analyse fréquentielle d'Al-Kindi** : mesurer la fréquence des lettres du chiffré, comparer avec les fréquences de la langue (en français, E est la plus fréquente), en déduire l'alphabet.

Substitution 2 : chiffre de Vigenère

Amélioration décisive de César : la clé est un mot répété sous le texte, et **une même lettre claire est chiffrée différemment** (résiste à l'analyse fréquentielle simple). Avec la table : intersection colonne = lettre claire, ligne = lettre de clé. Avec les nombres (A = 0 … Z = 25) :

```
C_i = (L_i + k_i) \bmod 26
```

Clair	Clé répétée	Chiffré
VIGENERE	CODESCOD	XWJIFGFH
DCODE	CLECL	FNSFP

Détail DCODE : D(3)+C(2)=5 → F ; C(2)+L(11)=13 → N ; O(14)+E(4)=18 → S ; D(3)+C(2)=5 → F ; E(4)+L(11)=15 → P.

Transposition

- **Par blocs** : on écrit le message en lignes dans une grille (ex. blocs de 3×3) et on lit par colonnes.
- **Matricielle avec clé** : message écrit ligne par ligne dans une matrice dont la largeur = longueur de la clé ; on numérote les colonnes selon l'ordre alphabétique des lettres de la clé et on lit les colonnes dans cet ordre. Exemple : clé ESPOIR → ordre E=1, S=6, P=4, O=3, I=2, R=5 ; on lit la colonne 1, puis celle sous I, puis O, P, R, S.

Méthode d'exercice : (1) écrire le clair en lignes sous la clé ; (2) numéroter les lettres de la clé par ordre alphabétique ; (3) lire chaque colonne de haut en bas dans l'ordre des numéros.

5. Cryptographie moderne

La logique du cours : le symétrique est rapide mais pose le problème de l'échange de clé → l'asymétrique le résout mais est lent → le **hybride** combine les deux → la **signature** apporte intégrité, authentification, non-répudiation → les **certificats/PKI** garantissent qu'une clé publique appartient bien à son détenteur.

5.1 Cryptographie symétrique (à clé privée/secrète)

Même clé pour chiffrer et déchiffrer (ke = kd = k), possédée par les deux parties. Exemples : DES, 3DES, RC2–RC6, AES.

	DES	AES
Type	Chiffrement par blocs itératif, **schéma de Feistel**	Chiffrement par blocs à plusieurs tours (réseau substitution-permutation)
Bloc	64 bits	128 bits (tableau d'état 4×4 octets)
Clé	56 bits + 8 bits de parité (= 64) ; sous-clés de 48 bits	128, 192 ou 256 bits
Tours	16	10 / 12 / 14 (selon clé 128 / 192 / 256)
Déchiffrement	Identique au chiffrement, sous-clés **en ordre inverse**	Opérations inverses

Étapes DES : (1) permutation initiale IP ; (2) 16 tours : le bloc est coupé en deux moitiés de 32 bits (G, D) échangées selon Feistel ; la fonction de tour fait **expansion** 32 → 48 bits, **XOR** avec la sous-clé de 48 bits, **substitution par S-box** (48 → 32), **permutation** ; (3) permutation finale IP^{-1}. Sous-clés générées depuis la clé (permutations, décalages).

Étapes AES : initialisation = bloc recopié verticalement dans la matrice d'état 4×4 + **AddRoundKey** (XOR sous-clé 0). Puis à chaque tour : **SubBytes** (confusion : substitution de chaque octet), **ShiftRows** (décalage des 3 dernières lignes de pas différents), **MixColumns** (diffusion : multiplication polynomiale des colonnes), **AddRoundKey** (XOR sous-clé i).

Modes opératoires :

- **ECB** (Electronic Code Book) : chaque bloc chiffré indépendamment, Ci = Ek(Mi). Deux blocs clairs identiques → chiffrés identiques (faiblesse).
- **CBC** (Cipher Block Chaining) : blocs chaînés, Ci = Ek(Mi ⊕ Ci−1), avec C0 = **IV** (vecteur d'initialisation). Effet d'avalanche ; chaque bloc dépend de tous les précédents.

Avantages / limites du symétrique :

- Avantage : **très rapide**.
- Shannon (années 1940) : sécurité parfaite si la clé est au moins aussi longue que le message.
- Exige un **canal sécurisé** pour échanger la clé.
- Nombre de clés pour N personnes : **N(N−1)/2** (ex. 10 personnes → 45 clés ; 100 → 4 950).

Protocole du double cadenas (échange sans clé commune) : (1) Alice chiffre avec sa clé CA et envoie ; (2) Bob surchiffre avec CB et renvoie ; (3) Alice retire CA et renvoie ; (4) Bob déchiffre avec CB. Limites : l'ordre d'envoi/réception doit être respecté, et les deux

doivent être présents → naissance de l'asymétrique.

5.2 Cryptographie asymétrique (à clé publique)

Chaque entité a une paire : **clé publique** (connue de tous, sert à **chiffrer**) et **clé privée** (secrète, sert à **déchiffrer**). Basée sur des fonctions faciles dans un sens et très difficiles à inverser : factorisation/exponentiation de grands premiers (**RSA**), logarithme discret (**ElGamal**), sac à dos (**Merkle-Hellman**).

RSA — génération des clés :

1. Choisir deux grands premiers p et q.
2. n = p × q.
3. φ(n) = (p − 1)(q − 1) (indicatrice d'Euler, notée aussi z).
4. Choisir e premier avec φ(n), 1 < e < φ(n).
5. Calculer d tel que e × d ≡ 1 (mod φ(n)).
6. Clé publique PK = (e, n) ; clé privée SK = (d, n).

```
c = m^{e} \bmod n \qquad m = c^{d} \bmod n
```

Limite : très gourmand en calcul, environ **1000 fois plus lent qu'AES** → on l'utilise pour distribuer des clés symétriques.

5.3 Cryptographie hybride

Le message est chiffré avec une **clé de session symétrique** (rapide) ; cette clé de session est chiffrée avec la **clé publique du destinataire**. Le destinataire déchiffre la clé de session avec sa clé privée, puis le message. (Principe utilisé par TLS.)

5.4 Signature numérique

Jusqu'ici seule la **confidentialité** est assurée ; la signature apporte **authentification, intégrité, non-répudiation**.

- Principe : l'émetteur chiffre avec **sa clé privée** ; tout le monde vérifie avec **sa clé publique** (inverse du chiffrement pour confidentialité).
- Signer tout le message est lent et volumineux → on signe l'**empreinte** (hash) : fonction à sens unique, entrée de taille variable → sortie de taille fixe ; la moindre modification change l'empreinte.
- Schéma : émetteur calcule H(M), le chiffre avec sa clé privée = signature, envoie M + signature. Le récepteur déchiffre la signature avec la clé publique de l'émetteur, recalcule H(M) et compare : égalité ⇒ intégrité + authenticité.
- Fonctions de hachage : **MD5** → 128 bits ; **SHA-1** → 160 bits.

5.5 Certificats numériques et PKI

Problème : un pirate peut publier une fausse clé publique au nom du destinataire (base du MITM) → il faut prouver qu'une clé publique appartient à son détenteur.

Certificat (émis par une **Autorité de Certification, CA**) = clé publique + informations d'identité (nom, ID…) + une ou plusieurs signatures numériques (celle de la CA atteste les infos). Formats vus : **PGP** et **X.509**. Analogie : permis de conduire, carte d'identité.

Principe : (1) Alice demande la certification de sa clé publique à la CA ; (2) la CA vérifie les infos, émet le certificat dans un annuaire ; (3) Bob récupère le certificat d'Alice et le certificat auto-signé de la CA, et vérifie l'intégrité grâce à la signature de la CA.

PKI (Infrastructure à clé publique) : ensemble d'éléments, protocoles et services pour gérer les clés publiques à grande échelle : enregistrement et émission, stockage et distribution, **révocation** et vérification de statut, utilisation des certificats. Composantes : matérielle, logicielle, humaine, organisationnelle, administrative, financière.

Résumé à connaître par cœur : Confidentialité = chiffrement hybride (clé de session symétrique pour le message, asymétrique pour la clé). Intégrité / authentification / non-répudiation = hachage + signature numérique, certificats pour authentifier les clés publiques.

6. Contrôle d'accès (chapitre 4)

Le contrôle d'accès associe des droits d'accès à une entité (personne, ordinateur…) pour qu'elle n'accède qu'aux ressources autorisées. Il peut être **physique** (bâtiment, local) ou **logique** (OS, application), via mot de passe, carte, clé, biométrie. Il précise : **qui** est autorisé à faire **quoi** (lecture, écriture), **sur quelles données**, **dans quelles conditions**.

Types de règles : indépendantes du contenu (Alice et Bob lisent/modifient toutes les infos RH), dépendantes du contenu (Eric lit le salaire de **son propre** dossier), délégation (Diane autorise Charlie à lire les heures sup).

Le protocole AAA

1. **Authentification** : vérifier que l'utilisateur est bien qui il prétend être (login/mot de passe, carte à puce…).
2. **Autorisation** : vérifier que l'utilisateur authentifié a les **droits** nécessaires (on peut être authentifié sans être autorisé).
3. **Accounting (traçabilité)** : journaliser les accès (heure de connexion, actions) contre l'usurpation de droits.

Les 4 modèles

Modèle	Qui décide / sur quelle base	Point clé
RBAC (Role-Based)	Droits selon la **fonction métier (rôle)**, pas l'identité ni l'ancienneté	Moindre privilège : seulement les données nécessaires au poste
ABAC (Attribute-Based)	Combinaison d'**attributs** et de conditions d'environnement (heure, lieu)	Le plus **granulaire**, réduit le nombre d'affectations de rôles
DAC (Discretionary)	Chaque objet a un **propriétaire** qui accorde l'accès à sa discrétion	Contrôle au cas par cas (ex. partage de fichiers)
MAC (Mandatory)	Une **autorité centrale** attribue des autorisations organisées en **niveaux**	Contextes gouvernementaux et militaires (Confidentiel, Secret…)

Piège classique : DAC = le **propriétaire** décide ; MAC = l'**autorité centrale** impose.

7. SSL/TLS : tunnel sur la couche transport (chapitre 5)

SSL (Netscape, 1994) crée des tunnels au **niveau 4 OSI**, uniquement pour les flux **TCP**. HTTP devient **HTTPS (port 443)** ; aussi POP, FTP, SMTP, LDAP. Netscape a confié SSL à l'IETF : **TLS 1.0 = SSL 3.1**.

Services : authentification forte par certificats, chiffrement, compression, négociation des algorithmes, gestion des clés de session. **Propriétés** : échange sécurisé de clés, authentification du serveur (optionnelle mais courante), authentification du client (optionnelle, rare), confidentialité et intégrité.

Architecture (pile)

Application (HTTP, FTP, SMTP) → SSL/TLS → TCP → IP. TLS contient 4 sous-protocoles au-dessus du **Record Layer** :

- **Handshake** : initialisation de la communication client/serveur (négociation, authentification, clés).
- **Change Cipher Spec** : indique au Record Layer d'activer les algorithmes qui viennent d'être négociés.
- **Alert** : traitement des erreurs.
- **Application** : communications avec l'application.

- **Record Layer** (en dessous) : compression, chiffrement et contrôle d'intégrité des données.

Établissement du tunnel (handshake) — à savoir dans l'ordre

1. Client → **Client Hello** : CipherSuites proposées + Client Random.
2. Serveur → **Server Hello** : CipherSuite choisie + Server Random.
3. Serveur → **Certificate** (contenant sa clé publique KpubS) ou **Server Key Exchange**.
4. Serveur → **Server Hello Done** (négociation terminée).
5. Client → **Client Key Exchange** : la **PreMasterKey** choisie par le client, chiffrée avec KpubS.
6. Client → **Change Cipher Spec** (activation du chiffrement) puis **Finished**.
7. Serveur → **Change Cipher Spec** puis **Finished**.
8. Échanges applicatifs chiffrés symétriquement avec **6 clés**.

Exemple de CipherSuite : RSA (asymétrique, authentification) + AES-128 en mode CBC (confidentialité) + SHA (intégrité).

Génération des 6 clés de session (KDF)

PreMasterKey → **MasterKey** (calculée simultanément des deux côtés) → 6 clés :

Clé	Rôle
Client Cipher	Chiffrer client → serveur
Server Cipher	Chiffrer serveur → client
Client MAC	HMAC côté client (intégrité)
Server MAC	HMAC côté serveur (intégrité)
Client IV	Vecteur d'initialisation CBC du client
Server IV	Vecteur d'initialisation CBC du serveur

HMAC (Hash-based Message Authentication Code), avec h = MD5 ou SHA, K = clé MAC complétée de zéros, ipad = 0x36 répété, opad = 0x5C répété, ‖ = concaténation :

$$HMAC_K(m) = h\big((K \oplus opad) \,\|\, h((K \oplus ipad) \,\|\, m)\big)$$

Record Protocol : le message M est découpé en fragments (M0, M1, M2…), chacun reçoit un MAC puis est chiffré (CBC avec l'IV).

8. IPsec : tunnel sur la couche IP (chapitre 5)

IPsec protège le trafic **au niveau IP** (IPv4 et IPv6), donc IP et tous les protocoles au-dessus. **Optionnel en IPv4, obligatoire en IPv6**. Standard IETF : 1er RFC en 1995 (sans gestion de clés), 2e version en novembre 1998 avec **IKE**. Implémentations : native, **BITS** (Bump in the Stack, logiciel ajouté), **BITW** (Bump in the Wire, processeur crypto externe).

Services : confidentialité, authentification de l'origine, intégrité, **protection contre le rejeu**, protection partielle contre l'analyse de trafic.

AH vs ESP

	AH (Authentication Header)	ESP (Encapsulating Security Payload)
Intégrité	Oui	Oui
Authentification de l'origine	Oui	Oui (optionnelle)
Anti-rejeu	Oui	Oui
Confidentialité (chiffrement)	**Non**	**Oui** (rôle premier)
Principe	Ajoute un champ d'authentification au datagramme	Crée un nouveau datagramme dont les données (et éventuellement l'en-tête d'origine) sont chiffrées

Mode transport vs mode tunnel

	Transport	Tunnel
Où agit IPsec	Entre TCP et IP	Après l'encapsulation IP
Ce qui est protégé	Seulement les données (payload) de la couche supérieure	**Tout le paquet IP**, en-tête d'origine compris
En-tête IP	Inchangé : pas de masquage d'adresses	Nouvel en-tête ; adresses d'origine masquées
Utilisation	Équipements **terminaux** uniquement ; simple à mettre en œuvre	Terminaux **et passerelles** ; **VPN** ; meilleure protection contre l'analyse de trafic

Format tunnel ESP : `[Nouvel en-tête IP][ESP header][En-tête IP d'origine + payload + ESP trailer (chiffrés)][ESP auth]`.

Association de sécurité (SA), SAD, SPD

- **SA** : relation **unidirectionnelle** entre émetteur et destinataire, définissant les opérations IPsec à appliquer ; il en faut **une par sens**.
- Identifiée par le triplet : **adresse de destination + protocole (AH ou ESP) + SPI**. Le **SPI** (Security Parameter Index) fait **32 bits**, est en clair dans chaque paquet et est **choisi par le récepteur**.
- Contenu d'une SA : SPI, algorithme de chiffrement (AES, 3DES), algorithme d'authentification (SHA-256), clés symétriques, durée de vie, mode (tunnel/transport), adresse IP du pair.
- **SAD** (Security Association Database) : stocke toutes les SA actives, consultée pour chaque paquet.
- **SPD** (Security Policy Database) : dit **quel trafic** protéger, selon IP source/destination, protocole, ports. Actions : **PROTECT** (IPsec, IKE négocie une SA), **BYPASS** (en clair), **DISCARD** (bloquer).

Gestion des clés : IKE

Deux solutions pour remplir les SA : configuration **manuelle** (déconseillée) ou **négociation dynamique** avec **IKE** = **ISAKMP** (négociation préalable des SA) + **Oakley** (mécanisme d'échange automatique des clés). IKE démarre **avant** IPsec : d'abord un tunnel IKE, puis le tunnel IPsec.

	Phase 1 (SA ISAKMP / IKE SA)	Phase 2 (SA IPsec)
But	Authentifier les pairs, établir la politique IKE et un canal sûr	Négocier les SA IPsec (transform-sets, ex. ESP-DES) et générer les clés IPsec
Algorithme clé	**Diffie-Hellman**	Crypto symétrique (rapide), protégée par la SA IKE
Authentification	Clé pré-partagée (PSK) ou signature RSA / certificats	Bloc HASH après l'en-tête ISAKMP
Paramètres	Chiffrement DES/3DES, hachage MD5/SHA-1, groupe DH, durée de vie (≥ 86 400 s)	Adresses des hôtes à chiffrer, algorithmes IPsec

	Phase 1 (SA ISAKMP / IKE SA)	Phase 2 (SA IPsec)
Modes	**Main mode** : 6 messages, protège l'identité. **Aggressive mode** : 3 messages, révèle l'identité, plus rapide	**Quick mode** : 3 messages

Main mode, 3 paires de messages : (1–2) négocier les paramètres IKE (chiffrement, hash, méthode d'authentification, groupe DH) ; (3–4) échange Diffie-Hellman → secret partagé **SKEYID** et clés de session ; (5–6) authentification mutuelle des échanges.

Quick mode (phase 2) : Bob propose les paramètres des SA IPsec + un nouveau nombre aléatoire (nonce) ; Alice répond avec son choix et son nonce (preuve qu'elle a reçu celui de Bob) ; Bob accuse réception de la même façon.

Synthèse IPsec : AH/ESP protègent les données ; leurs paramètres sont dans les **SA** (SAD) ; **IKE** gère les SA ; les **politiques** (SPD) définissent le trafic à protéger et indiquent à IKE les tunnels à créer.

TLS ou IPsec ?

	SSL/TLS	IPsec
Couche	Transport (4)	Réseau (3)
Protège	Flux TCP d'une application	Tout le trafic IP
Gestion des clés	Handshake (PreMasterKey → MasterKey → 6 clés)	IKE (ISAKMP + Oakley, Diffie-Hellman)
Usage type	HTTPS	VPN (mode tunnel)

9. Fiche flash et exercice type

Exercice RSA résolu (petits nombres)

p = 3, q = 11.

1. n = 3 × 11 = **33**.
2. φ(n) = 2 × 10 = **20**.
3. e = **3** (pgcd(3, 20) = 1).
4. d tel que 3d ≡ 1 (mod 20) → d = **7** (car 21 = 1 × 20 + 1).
5. PK = (3, 33), SK = (7, 33).

6. Chiffrer m = 4 : $c = 4^3 \bmod 33 = 64 \bmod 33 =$ **31**.
7. Déchiffrer : $31^7 \bmod 33$. Astuce : $31 \equiv -2$, donc $(-2)^7 = -128 \equiv -128 + 4 \times 33 =$ **4** ✔.

Méthode pour trouver d : essayer k = 1, 2, 3… jusqu'à ce que $(k \times \varphi(n) + 1)$ soit divisible par e ; alors $d = (k \times \varphi(n) + 1) / e$. Pour les grandes puissances, décomposer (ex. $x^7 = x^4 \times x^2 \times x$) en réduisant modulo n à chaque étape.

Questions-réponses éclair

Question	Réponse
Virus vs ver ?	Le virus a besoin d'un hôte ; le ver se propage seul via le réseau
DoS vs DDoS ?	Une seule source vs plusieurs sources
Pourquoi un switch contre le sniffing ?	Le hub diffuse chaque trame à tous ; le switch l'envoie au seul destinataire
XSS réfléchie vs stockée ?	Script dans la requête renvoyé une fois vs script enregistré en base, exécuté à chaque affichage
Parade CSRF ?	Jeton CSRF aléatoire par requête + cookie SameSite
Parade injection SQL ?	Requêtes préparées, validation des entrées
Stéganographie vs cryptographie ?	Cacher l'existence vs rendre incompréhensible
Faiblesse de César ?	26 clés (force brute) + analyse fréquentielle (Al-Kindi)
DES : bloc / clé / tours ?	64 bits / 56 bits (+8 parité) / 16 tours Feistel
AES : bloc / clé / tours ?	128 bits / 128-192-256 / 10-12-14
4 opérations d'un tour AES ?	SubBytes, ShiftRows, MixColumns, AddRoundKey
ECB vs CBC ?	Blocs indépendants vs chaînés avec IV
Nb de clés symétriques pour N personnes ?	$N(N-1)/2$
Chiffrer pour confidentialité ?	Avec la clé **publique du destinataire**
Signer ?	Avec la clé **privée de l'émetteur**, sur le hash du message
MD5 / SHA-1 ?	128 bits / 160 bits

Question	Réponse
Rôle d'un certificat ?	Lier une clé publique à une identité, signé par une CA (contre le MITM)
AAA ?	Authentification, Autorisation, Accounting (traçabilité)
DAC vs MAC ?	Propriétaire décide vs autorité centrale par niveaux
TLS : couche, port HTTPS ?	Transport (4), port 443
Combien de clés TLS, lesquelles ?	6 : Client/Server Cipher, Client/Server MAC, Client/Server IV
AH chiffre-t-il ?	Non : intégrité + authentification + anti-rejeu seulement ; ESP chiffre
Mode pour un VPN ?	Tunnel (masque les adresses d'origine)
Identification d'une SA ?	@ destination + protocole (AH/ESP) + SPI (32 bits, choisi par le récepteur)
SA uni- ou bidirectionnelle ?	Unidirectionnelle : une par sens
IKE = ?	ISAKMP + Oakley ; phase 1 (Diffie-Hellman, main 6 msg / aggressive 3 msg), phase 2 (quick mode)
Actions du SPD ?	PROTECT, BYPASS, DISCARD

Conseils pour l'examen

- Pour toute attaque : **définition → fonctionnement → exemple réel → protection**.
- Entraînez-vous à la main sur César, Vigenère, une transposition à clé et un RSA à petits nombres.
- Sachez dessiner : le handshake TLS (8 étapes), les modes transport/tunnel IPsec, le schéma de signature (hash + clé privée).

Note : plusieurs diapositives du cours n'étaient que des schémas (DES détaillé, hybride, signature, PKI) ; les explications correspondantes ici sont reconstruites à partir du texte du cours et des notions standard — vérifiez-les avec vos schémas.